

ENTERPRISE NETWORK SECURITY ASSESSMENT AND DEFENSE PLANNING

Prepared by the Office of Information Security

Organization:	Apex Solutions Pvt. Ltd.
Assessment Type:	Internal Network Security Review
Date:	March 2026

Analyst: Junior Cyber Security Analyst | Division: Information Security

1. Executive Summary

Apex Solutions Pvt. Ltd. engaged the Information Security team to conduct a comprehensive network security assessment following reports of anomalous network activity. This assessment covers the company's internal LAN infrastructure, internet-facing services, wireless networks, and endpoint security posture for an organization of approximately 50–100 employees.

The assessment team reviewed network architecture, analyzed potential attack surfaces, and evaluated existing security controls. This report presents findings organized by severity, along with prioritized recommendations to reduce risk and strengthen the organization's overall cyber defense posture.

1.1 Key Findings at a Glance

Severity	Findings	Remediated	Status
Critical	3	0	Immediate action required
High	5	0	Remediate within 30 days
Medium	6	2	Remediate within 90 days
Low	4	1	Remediate within 180 days

Overall Risk Rating: HIGH — The network exhibits several critical misconfigurations and control gaps that require urgent attention.

2. Scope and Methodology

2.1 Assessment Scope

The following components were included in this assessment:

- Internal Local Area Network (LAN) — wired and wireless segments
- Edge router and perimeter firewall
- Core and access-layer network switches
- Internet-facing services: web server, email gateway, VPN endpoint
- Employee and guest Wi-Fi infrastructure
- Endpoint devices: workstations, laptops, mobile devices
- Identity and access management policies
- Network monitoring and logging infrastructure

2.2 Assessment Methodology

This assessment followed a structured, defense-focused methodology aligned with industry frameworks including NIST SP 800-115, CIS Controls v8, and ISO/IEC 27001:

- Phase 1 — Discovery: Network enumeration, architecture review, and component identification
- Phase 2 — Threat Modeling: Identification of threat actors, attack vectors, and likely scenarios
- Phase 3 — Vulnerability Analysis: Examination of open ports, service banners, credential policies, and wireless configurations
- Phase 4 — Risk Evaluation: Qualitative risk scoring based on Likelihood × Impact
- Phase 5 — Defense Strategy: Recommendation of countermeasures, controls, and architectural improvements

Note: This was a passive, non-intrusive assessment. No exploitation or penetration testing was conducted. All findings are based on configuration review, architecture analysis, and observed network behavior.

3. Network Architecture & Mapping

3.1 Current Network Overview

Apex Solutions operates a flat-to-mildly-segmented network with approximately 50–100 endpoints. The network consists of the following primary zones:

Network Zone	IP Range	Description
Internet DMZ	203.0.113.0/29	Public-facing servers: web, email, VPN
Internal Corporate LAN	10.10.0.0/22	Employee workstations, printers, phones
Server/Data VLAN	10.10.4.0/24	File servers, databases, application servers
Management VLAN	10.10.5.0/24	Network device management interfaces
Employee Wi-Fi	192.168.1.0/24	Wireless access for corporate employees
Guest Wi-Fi	192.168.2.0/24	Isolated wireless for visitors and contractors

3.2 Critical System Inventory

The following systems were identified as critical assets requiring elevated security controls:

- Primary Domain Controller (DC01) — Active Directory, DNS, DHCP
- File Server (FS01) — Internal file shares and document repositories
- Email Gateway — On-premise mail relay and filtering
- Web Server — External corporate website and customer portal
- VPN Concentrator — Remote access for employees
- Database Server — Customer and financial data storage
- Network Access Control (NAC) appliance — Currently disabled

3.3 Observed Architecture Weaknesses

A review of the network topology revealed several structural concerns:

- Insufficient network segmentation: Employee workstations can communicate directly with the server VLAN without restriction
- No DMZ isolation: The web server has direct inbound access paths to internal systems
- Guest Wi-Fi not fully isolated: Default gateway misconfiguration allows limited internal routing
- Management VLAN accessible from general employee segment via misconfigured ACL

4. Threat Identification

4.1 Threat Landscape Overview

Based on the organization's size, industry exposure, and network architecture, the following threat categories were identified as relevant and plausible:

Threat Category	Threat Actor	Likelihood	Primary Concern
Unauthorized External Access	External Attacker	HIGH	Exploitation of open ports and weak services
Malware / Ransomware	Cybercriminal Group	HIGH	Lateral movement via flat LAN structure
Insider Threat	Disgruntled Employee	MEDIUM	Excessive access rights, lack of monitoring
Phishing / Social Engineering	Multiple	HIGH	Credential harvesting, malware delivery
Wireless Attacks (Evil Twin / Deauth)	Proximate Attacker	MEDIUM	Rogue AP interception, credential capture
Supply Chain / Third-Party Risk	Vendor / Contractor	MEDIUM	Unmanaged devices introduced to network
DDoS Attack	Hackivist / Criminal	LOW	Service disruption to internet-facing assets

4.2 Detailed Threat Scenarios

4.2.1 Ransomware via Phishing

An attacker sends a crafted phishing email to an employee, who opens a malicious attachment. Malware executes on the workstation and, due to the flat LAN structure, propagates laterally to shared file servers and backup systems before encrypting data. The lack of endpoint detection and response (EDR) means detection occurs only after significant damage.

4.2.2 External Exploitation of Open Services

An attacker scans the company's public IP range and identifies several open ports including SSH (22), RDP (3389), and an unpatched web application running on port 8080. Brute-force or exploit attempts against these services could yield unauthorized access to the DMZ or internal systems.

4.2.3 Rogue Wireless Access Point

A threat actor within physical proximity sets up a rogue access point with the same SSID as the corporate Wi-Fi. Employees connect and their credentials or session tokens are captured via a man-in-the-middle attack, particularly impacting users on unencrypted internal applications.

5. Vulnerability and Risk Analysis

5.1 Open Port and Service Exposure

A review of publicly accessible IP addresses revealed the following exposed services, many of which are unnecessary or misconfigured:

Port	Service	State	Risk Level	Issue
22	SSH	OPEN	HIGH	Accessible from any IP; password auth enabled
23	Telnet	OPEN	CRITICAL	Unencrypted protocol; should be disabled
80	HTTP	OPEN	MEDIUM	Redirects to HTTPS but not enforced
443	HTTPS	OPEN	LOW	TLS 1.0 still enabled alongside TLS 1.3
445	SMB	OPEN	CRITICAL	SMBv1 enabled; EternalBlue risk
3389	RDP	OPEN	CRITICAL	Internet-facing RDP; BlueKeep patches missing
8080	HTTP-Alt	OPEN	HIGH	Unsecured test/dev server exposed externally

5.2 Access Control Weaknesses

- Default credentials in use on at least two managed switches (Cisco IOS, admin/cisco)
- No enforced password complexity policy — several accounts with passwords under 8 characters detected
- 15 stale Active Directory accounts for former employees remain enabled
- Shared service account credentials used across multiple systems without individual attribution
- Privileged accounts (Domain Admin) used for day-to-day activities on workstations
- No Multi-Factor Authentication (MFA) enforced for VPN or remote access logins

5.3 Wireless Security Gaps

- Employee Wi-Fi uses WPA2-Personal (PSK) — no certificate-based authentication (WPA2/3-Enterprise)
- Guest SSID is on the same physical infrastructure with only VLAN separation; no client isolation
- Wi-Fi password has not been rotated in over 18 months; shared with contractors and visitors
- Management interface of the wireless controller accessible from the employee Wi-Fi segment
- No wireless intrusion prevention system (WIPS) in place to detect rogue access points

5.4 Monitoring and Logging Deficiencies

- No centralized SIEM or log aggregation platform deployed
- Firewall logging disabled on the internal interface — only perimeter events captured
- No alerting configured for brute-force attempts, after-hours logins, or lateral movement indicators
- Network traffic between segments not inspected — east-west traffic is unrestricted
- Log retention period is 14 days — insufficient for forensic investigation of a slow-burn attack

6. Risk Register

The table below presents a consolidated risk register mapping identified threats to their potential impact and recommended mitigations. Risks are scored using a qualitative Likelihood × Impact matrix.

Threat / Vulnerability	Likelihood	Impact	Risk	Recommended Mitigation
Internet-facing RDP (3389) open	Very High	Critical	CRITICAL	Block RDP at perimeter; enforce VPN-only access; apply BlueKeep patches
SMBv1 enabled on network shares	High	Critical	CRITICAL	Disable SMBv1 immediately; enforce SMB signing; patch all systems
Telnet enabled on network devices	High	High	CRITICAL	Disable Telnet; enforce SSH v2 with key-based authentication only
No MFA on VPN / remote access	High	High	HIGH	Deploy TOTP/FIDO2 MFA for all remote access immediately
Stale AD accounts (15 enabled)	Medium	High	HIGH	Audit and disable all inactive accounts; automate offboarding
Default device credentials in use	High	Medium	HIGH	Rotate all default credentials; enforce device hardening baseline
Flat LAN — no east-west controls	Medium	High	HIGH	Implement micro-segmentation; deploy internal firewall ACLs
No SIEM / centralized logging	High	Medium	HIGH	Deploy SIEM (e.g., Wazuh or Splunk); aggregate all log sources
WPA2-PSK on corporate Wi-Fi	Medium	Medium	MEDIUM	Migrate to WPA3-Enterprise with 802.1X and RADIUS authentication
No rogue AP detection (WIPS)	Medium	Medium	MEDIUM	Enable WIPS on wireless controller; deploy dedicated sensor
TLS 1.0 still active on web server	Low	Medium	MEDIUM	Disable TLS 1.0/1.1; enforce TLS 1.2 minimum with strong ciphers
Dev server (8080) exposed publicly	Medium	Medium	MEDIUM	Move dev/test systems to isolated internal VLAN; remove public access
14-day log retention only	Medium	Low	MEDIUM	Extend log retention to 90+ days; archive cold logs to secure storage
Privileged accounts used daily	Medium	Medium	MEDIUM	Enforce Privileged Access Workstations (PAW); separate admin accounts
Guest Wi-Fi — no client isolation	Low	Low	LOW	Enable AP client isolation; review and tighten guest VLAN firewall rules

HTTP not fully redirected to HTTPS	Low	Low	LOW	Enforce HTTP-to-HTTPS redirect with HSTS header on all web services
No EDR on endpoints	Medium	High	HIGH	Deploy EDR solution (e.g., CrowdStrike Falcon, Microsoft Defender ATP)
No network IDS/IPS deployed	Medium	Medium	MEDIUM	Deploy Suricata or Snort IDS at network choke points; tune rulesets

7. Defense Strategy and Recommendations

7.1 Firewall Configuration

The following firewall rule changes are recommended as an immediate priority:

Rule #	Source	Destination	Action	Justification
FW-001	Any (Internet)	0.0.0.0/0 : 3389	DENY	Block all inbound RDP from internet; RDP must traverse VPN only
FW-002	Any (Internet)	0.0.0.0/0 : 23	DENY	Block all Telnet; protocol is obsolete and unencrypted
FW-003	Any (Internet)	0.0.0.0/0 : 8080	DENY	Block dev server port; not required from internet
FW-004	Guest Wi-Fi (192.168.2.0/24)	Internal LAN (10.10.0.0/22)	DENY	Guest segment must have no access to internal corporate resources
FW-005	Employee LAN (10.10.0.0/22)	Server VLAN (10.10.4.0/24)	ALLOW specific	Only required ports and services to listed server IPs allowed
FW-006	Any	Management VLAN (10.10.5.0/24)	DENY	Management VLAN accessible only from Admin PAW subnet
FW-007	Internet	DMZ Web Server	ALLOW 80, 443	HTTP/HTTPS only; all other ports blocked at perimeter
FW-008	DMZ	Internal LAN	DENY	No direct paths from DMZ to internal network without proxy

7.2 IDS/IPS Deployment Plan

An Intrusion Detection / Prevention System should be deployed in the following locations to maximize visibility:

- Placement 1 — Internet Edge (inline IPS): Deploy between the edge router and perimeter firewall to detect inbound exploit attempts, port scans, and known malware C2 traffic
- Placement 2 — Internal Core Switch (IDS tap): Deploy a passive IDS sensor on a SPAN port of the core switch to monitor east-west (internal) traffic for lateral movement and anomalous behavior
- Placement 3 — DMZ Segment: Place an IDS sensor to monitor all traffic to/from internet-facing servers and alert on exploitation attempts
- Recommended tool: Suricata (open source) or Snort 3 with Emerging Threats ruleset; integrate alerts to SIEM

7.3 Network Segmentation Plan

The recommended target architecture implements defense-in-depth through strict network segmentation:

- Implement VLANs for: Corporate LAN, Server/Data, Management, DMZ, Employee Wi-Fi, Guest Wi-Fi, and IoT/Printer segments
- Deploy inter-VLAN routing through the firewall only — eliminate direct switch-level routing between segments
- Apply the principle of least privilege: workstations communicate only with required services on allowed ports
- Isolate the Management VLAN entirely — accessible only via jump host / PAW with MFA enforced
- Create a dedicated IoT/Printer VLAN to isolate potentially vulnerable embedded devices

7.4 Secure Wi-Fi Configuration

- Upgrade corporate Wi-Fi from WPA2-PSK to WPA3-Enterprise with 802.1X authentication via RADIUS
- Deploy certificates to managed devices for seamless employee authentication without shared passwords
- Enable AP-level client isolation on the guest SSID to prevent guest-to-guest communication
- Implement a captive portal on guest Wi-Fi with terms of use acceptance and time-limited sessions
- Enable Wireless Intrusion Prevention (WIPS) on the wireless LAN controller to detect rogue APs
- Rotate any remaining PSK-based Wi-Fi passwords immediately and audit who holds them

7.5 Identity and Access Management

- Enforce MFA (TOTP or hardware tokens) for all VPN, administrative, and remote access logins
 - Implement privileged access management (PAM) with time-limited, session-recorded admin access
 - Disable all 15 stale Active Directory accounts within 48 hours; create automated offboarding workflow
 - Enforce password complexity: minimum 14 characters with complexity rules; integrate with HIBP API to block breached passwords
 - Deploy a password manager for service accounts; eliminate shared credentials
-

7.6 Monitoring and Incident Response

- Deploy a SIEM platform (Wazuh, Splunk, or Microsoft Sentinel) aggregating logs from: firewall, switches, AD, endpoints, and web servers
 - Create detection rules for: brute-force attempts, off-hours logins, new admin accounts, lateral movement, mass file access, and outbound C2 communication
 - Extend log retention to a minimum of 90 days hot, 1 year cold
 - Establish an Incident Response (IR) plan with defined roles, communication trees, and runbooks for common scenarios (ransomware, data breach, insider threat)
 - Conduct quarterly tabletop exercises to validate IR readiness
-

8. Remediation Roadmap

The following prioritized roadmap is recommended for remediation. Items are sequenced to maximize risk reduction per effort expended:

Priority	Action Item	Timeline	Owner
P1 — CRITICAL	Block RDP (3389) at perimeter firewall; enforce VPN-only	Immediate (24 hrs)	Network Team
P1 — CRITICAL	Disable SMBv1 on all Windows systems; enable SMB signing	Immediate (24 hrs)	Systems Admin
P1 — CRITICAL	Disable Telnet on all network devices; enforce SSH v2	Immediate (48 hrs)	Network Team
P1 — CRITICAL	Disable all 15 stale Active Directory accounts	Immediate (48 hrs)	Identity Team
P2 — HIGH	Enforce MFA on VPN and all remote access	Week 1–2	IT / Security
P2 — HIGH	Rotate all default device credentials	Week 1–2	Network Team
P2 — HIGH	Deploy EDR on all endpoints	Week 2–4	Security Team
P2 — HIGH	Deploy SIEM and enable log aggregation	Week 2–4	Security Team
P3 — MEDIUM	Implement network segmentation (VLAN redesign)	Month 1–2	Network + Security
P3 — MEDIUM	Upgrade Wi-Fi to WPA3-Enterprise with 802.1X	Month 1–2	Network Team
P3 — MEDIUM	Deploy IDS/IPS at network choke points	Month 1–2	Security Team
P3 — MEDIUM	Disable TLS 1.0/1.1 on all web services	Month 1–2	Systems Admin
P4 — LOW	Enable AP client isolation on guest Wi-Fi	Month 2–3	Network Team
P4 — LOW	Enforce HTTPS redirect with HSTS on web server	Month 2–3	Web Team
P4 — LOW	Develop and test Incident Response plan	Month 3–6	CISO / Security
P4 — LOW	Conduct security awareness training for all staff	Month 3–6	HR + Security

9. Conclusion

This assessment has identified a significant number of vulnerabilities and security gaps across Apex Solutions' network infrastructure. The most critical findings — including internet-exposed RDP, SMBv1 protocol support, and the absence of multi-factor authentication — represent immediate, high-likelihood attack vectors that must be addressed without delay.

The organization's current network architecture, characterized by limited segmentation and unrestricted east-west traffic, creates conditions that would allow an attacker who compromises a single endpoint to rapidly propagate across the entire environment. This risk is compounded by the absence of centralized monitoring and detection capabilities.

With focused investment in the remediations outlined in this report — particularly network segmentation, MFA, endpoint protection, and SIEM deployment — the organization can substantially reduce its attack surface and achieve a significantly more resilient security posture within 60 to 90 days.

Recommended Next Step: Schedule a prioritization meeting with IT leadership and department heads within the next 5 business days to assign ownership and confirm timelines for all P1 and P2 remediation items.

9.1 Compliance Considerations

Depending on the organization's industry and data handling obligations, the following standards may be applicable and should be reviewed for alignment with the remediation actions described in this report:

- ISO/IEC 27001:2022 — Information Security Management System
- NIST Cybersecurity Framework (CSF) 2.0
- CIS Critical Security Controls v8
- PCI-DSS v4.0 (if cardholder data is processed)
- India DPDP Act 2023 (if personal data of Indian residents is processed)

Report Prepared by: Junior Cyber Security Analyst (VIVEK RAJ), Office of Information Security
